PLANO DE SEGURANÇA DA INFORMAÇÃO.

Nome: Kayky Charles Soares Costa.

1. Escopo, Objetivos e Governança (LGPD e Normas)

- **Objetivo:** Proteger a confidencialidade, integridade e disponibilidade dos dados de alunos, pais, professores e funcionários, garantindo a conformidade com a Lei Geral de Proteção de Dados (LGPD - Lei nº 13.709/2018).
- **Escopo:** Abrange todos os ativos físicos, digitais e humanos da instituição (Data Center local, servidores de arquivos, aplicações web/mobile, laboratórios e redes Wi-Fi).
- **Comitê de Segurança:** Formado pela Diretoria, Coordenação de TI, Coordenação Pedagógica e Encarregado de Proteção de Dados (DPO).

2. Inventário e Classificação de Ativos

Para proteger os recursos, é necessário mapear e classificar o que a instituição possui:

Categoria	Ativos Identificados	Nível de Criticidade	Classificação de Dados
Infraestrutura Local	Data Center *on-premise* (Servidores físicos, switches, firewalls)	Crítico	Confidencial / Interno
Armazenamento	Servidores de Arquivos (pastas compartilhadas de setores e acadêmico)	Alto	Restrito / Confidencial
Aplicações	Site institucional (hospedagem externa) e Aplicativo mobile	Médio/Alto	Público / Interno
Laboratórios e Estações	3 laboratórios (90 máquinas) + Desktops/Notebooks de funcionários	Médio	Interno / Público

3. Gestão de Identidades e Controle de Acesso (IAM)

O acesso aos sistemas deve seguir o **Princípio do Menor Privilégio** (cada usuário acessa apenas o estritamente necessário para sua função).

- **Matriz de Acessos:**
  - **Alunos:** Acesso exclusivo ao Portal do Aluno/App e redes Wi-Fi de convidados/alunos. Sem acesso aos servidores de arquivos internos ou rede administrativa.
  - **Professores:** Acesso ao sistema acadêmico, lançamento de notas, pastas de suas respectivas disciplinas no servidor de arquivos e Wi-Fi institucional.
  - **Funcionários Administrativos:** Acesso aos sistemas de gestão escolar (ERP),

dados financeiros de alunos e servidores de arquivos do setor.

- **Políticas de Autenticação:**
    - Obrigatoriedade de **Autenticação Multifator (MFA)** para contas administrativas, acessos remotos (VPN) e e-mails institucionais.
    - Senhas com complexidade mínima (mínimo de 10 caracteres, incluindo letras maiúsculas, minúsculas, números e símbolos) e troca obrigatória a cada 90 dias para contas privilegiadas.
    - Desativação imediata de contas de colaboradores e professores desligados.

4. Segurança de Perímetro e Infraestrutura de Rede

Com laboratórios de informática e grande circulação de alunos, a segmentação de rede é vital para evitar ataques de movimentação lateral.

- **Segmentação por VLANs:**
    - **VLAN 1 (Servidores / Data Center):** Isola os servidores locais, acessível apenas via regras estritas de firewall.
    - **VLAN 2 (Administrativo):** Estações de trabalho da secretaria e financeiro, com políticas rígidas de bloqueio de USB e navegação web controlada.
    - **VLAN 3 (Laboratórios e Acadêmico):** Máquinas dos 3 laboratórios com perfis restritos de usuário (contas sem privilégios de administrador local) para evitar instalação de malwares.
    - **VLAN 4 (Wi-Fi Visitantes/Alunos):** Rede isolada da rede corporativa/acadêmica interna, com portal cativo e isolamento de clientes (um dispositivo não enxerga o outro).
- **Proteção de Perímetro:**
    - Instalação de um **Firewall Next-Gen (NGFW)** na borda para inspeção de tráfego, prevenção de intrusão (IPS) e filtragem de conteúdo web.

5. Segurança do Aplicativo e do Site Institucional

Como o site é hospedado externamente e o app interage com a base de dados da instituição:

- **Site Institucional:** Garantir que a empresa de hospedagem utilize certificados SSL/TLS atualizados (HTTPS), proteção contra DDoS e firewalls de aplicação web (WAF). Realizar varreduras periódicas de vulnerabilidades.
- **Aplicativo Mobile:**
    - Comunicação via APIs seguras com criptografia em trânsito (HTTPS/TLS 1.3).
    - Implementação de boas práticas de desenvolvimento seguro (OWASP Top 10 Mobile), prevenindo injeções de código, armazenamento inseguro de credenciais no dispositivo e manipulação de tokens de sessão.

6. Proteção de Dados e Privacidade (LGPD)

Lidar com dados de menores de idade (alunos) exige conformidade redobrada:

- **Criptografia:**
    - Criptografia em repouso (AES-256) nos discos dos servidores de arquivos e Data Center que contêm dados pessoais sensíveis (documentos de matrícula, fichas médicas, dados financeiros).

    - Criptografia em trânsito para qualquer tráfego de credenciais e dados acadêmicos.
- **Minimização e Retenção:**
    - Coletar apenas os dados estritamente necessários para a prestação do serviço educacional.
    - Estabelecer prazos claros de retenção de dados após a conclusão ou evasão do aluno, respeitando as exigências legais de guarda documental escolar.

7. Plano de Continuidade de Negócios e Backup

Para mitigar riscos de falhas de hardware, queda de energia ou ataques de *ransomware* no Data Center local:

- **Estratégia de Backup 3-2-1:**
    - 3 cópias dos dados (1 original + 2 cópias de segurança).
    - 2 mídias diferentes (ex: armazenamento local em NAS/SAN e nuvem segura).
    - 1 cópia imutável e externa (*offsite* / nuvem), protegida contra criptografia por ransomware.
- **Frequência:**
    - Backups incrementais diários e backups completos (*full*) semanais.
    - Testes de restauração de arquivos e imagens de servidores realizados mensalmente para validar a integridade dos dados.
- **Infraestrutura Crítica:**
    - O Data Center on-premise deve contar com **No-breaks (UPS)** dimensionados para manter os servidores ativos durante quedas rápidas de energia e permitir o desligamento seguro, além de gerador para períodos estendidos.

8. Conscientização, Treinamento e Resposta a Incidentes

- **Campanhas de Phishing Simulado:** Treinamentos periódicos para funcionários e professores sobre como identificar e-mails maliciosos e engenharia social.
- **Procedimento de Resposta a Incidentes:**
    - **1. Identificação:** Detecção de anomalias (ex: picos de tráfego, criptografia inesperada de arquivos).
    - **2. Contenção:** Isolamento imediato da máquina ou servidor afetado da rede para evitar propagação.
    - **3. Erradicação e Recuperação:** Remoção da ameaça e restauração do ambiente através do último backup limpo validado.
    - **4. Notificação:** Acionamento do comitê de segurança e do DPO caso ocorra vazamento de dados pessoais (comunicação à ANPD e aos titulares em prazo legal).